

SILKinCOM

Report Problemi & Priorità di Intervento
Analisi tecnica completa del sito ecommerce
15 Maggio 2026

VERDETTO GENERALE

Dimensione	Status	Voto
Design & UX frontend	Eccellente	9/10
Architettura tecnica	Solida	8/10
Sicurezza	Lacune gravi	5/10
Funzionalità admin	Incompleto	6/10
Backend / API	Bug presenti	6/10
SEO & Performance	Ottimo	8/10

SEZIONE 1 — FRONTEND PUBBLICO

Cosa funziona bene

- Stack Next.js 15 + React 19 moderno e performante
- Design UI/UX lussuoso, coerente, animazioni Framer Motion fluide
- SEO metadata eccellenti: schema.org, OpenGraph, Twitter, breadcrumb, JSON-LD
- Static Generation (SSG) su prodotti e collezioni
- Internazionalizzazione next-intl (6 lingue: IT EN FR DE ES NL PT)
- Header security: CSP, HSTS, X-Frame-Options
- Font system elegante: Cormorant Garamond + Inter + Libre Baskerville
- CartDrawer con Zustand + persistenza locale

Problemi CRITICI

1. `src/app/checkout/CheckoutClient.tsx` — Nessun CSRF token sulle POST a `/api/stripe/create-payment-intent`
2. `src/components/product/WishlistButton.tsx` — Non controlla autenticazione PRIMA del fetch; race condition con doppio click
3. `src/app/checkout/CheckoutClient.tsx` — Price verification solo frontend; il backend deve riverificare i prezzi da DB

Problemi ALTI

1. `src/components/layout/Header.tsx` — Bottone Search presente ma senza handler onClick: funzionalità completamente assente
2. `src/app/cart/CartPageClient.tsx` — Shipping calculation non riflette correttamente lo sconto nel totale finale
3. `src/app/collezioni/[slug]/page.tsx` — Nessuna pagination: tutto carica sincrono, problema critico con 100+ prodotti

4. **src/components/product/ProductCard.tsx** — Nessun blur placeholder, nessun loading skeleton (CLS peggiora)

Problemi MEDI

1. **src/middleware.ts** — N+1 auth queries ad ogni request protetta, nessuna cache sessione
2. **next.config.js** — CSP con 'unsafe-inline' e 'unsafe-eval' in script-src (vulnerabile a XSS)
3. Nessun sorting prodotti (prezzo, novita, popolarita)
4. Nessun "ultimi X in stock" / sold-out state visibile al cliente

Funzionalità Mancanti

- Search globale prodotti (barra di ricerca)
- Filtri e sorting nelle collezioni (colore, materiale, prezzo, novita)
- Size guide / tabella misure per prodotto
- Guest checkout (attualmente obbligatorio registrarsi)
- Metodi pagamento alternativi (Apple Pay, Google Pay — già supportati da Stripe Elements)
- Inventory countdown: 'Rimasti solo 3!'
- Pagina tracking spedizione pubblica per il cliente

SEZIONE 2 — BACKEND & API

Cosa funziona bene

- Supabase RLS abilitato su tutte le tabelle critiche
- Stripe webhook con idempotency check e firma verificata (costruttore `stripe.webhooks.constructEvent`)
- Double opt-in newsletter con token crittograficamente sicuro (`randomBytes 24`)
- Gestione ordini con ownership check e time window (2 ore per cancellazione)
- Coupon validation: check globale + per cliente + ordine minimo + date
- Inventory decrement con RPC Supabase (locking atomico)
- Email transazionali con Resend (template HTML responsivo)

Problemi CRITICI

1. **src/app/api/orders/[id]/cancel/route.ts** — RACE CONDITION: UPDATE non atomico. Ordine 'pending' può essere cancellato mentre webhook Stripe lo marca 'paid'. Fix: aggiungere `.eq('status', 'pending')` nell'UPDATE in modo che fallisca atomicamente se lo stato è già cambiato.
2. **src/app/api/stripe/webhook/route.ts** — Restituisce 200 {received: true} anche quando `order_id` manca nei metadata. Stripe considera il webhook gestito e NON riprova. Ordine rimane nello stato errato per sempre. Fix: restituire 400 in caso di metadata invalidi.
3. **src/lib/email.ts** — HTML injection nelle email: `orderNumber` e altri valori dinamici inseriti in template HTML senza escaping. Un `orderNumber` malevolo può iniettare script o contenuti in email clients HTML. Fix: funzione `escapeHtml()` su tutti i valori dinamici.
4. **src/app/auth/callback/route.ts** — OPEN REDIRECT: parametro 'next' non validato. Attacker può costruire URL tipo `/auth/callback?code=valid&next=https://evil.com` e redirezionare utente autenticato verso sito esterno. Fix: whitelist dei domini permessi prima del redirect.

Problemi ALTI

1. **src/app/api/stripe/create-payment-intent/route.ts** — Nessun schema Zod su `shipping_address`, `customer_name`, `items[]`. Body malformato causa 500 generico invece di 400 con messaggio utile. Dati non validati vengono salvati in DB.
2. **src/app/api/reviews/route.ts** — Nessuna sanitizzazione su `title` e `comment`. Stringa tipo `'<img onerror=alert(1)>'` salvata in DB e renderizzata nel frontend causa XSS. Fix: `DOMPurify` o `regex plain-text`.
3. **src/lib/rate-limit.ts** — Store in-memory non condiviso tra istanze server. Con scaling orizzontale, ogni istanza ha limite indipendente. IP header (`x-forwarded-for`) spoofabile dal client se non c'è proxy fidato davanti. Fix: Redis distribuito (es. Upstash).

4. **src/lib/auth.ts** — `requireAuth()` lancia `throw new Error('Unauthorized')` invece di `NextResponse` con status 401. Causa risposta 500 generica invece del codice HTTP corretto.

Problemi MEDI

1. **src/app/api/coupons/validate/route.ts** — Timing attack: tempo risposta differisce tra coupon esistente e non esistente. Attacker può enumerare codici validi misurando latenza. Fix: delay costante nella risposta negativa.

2. **src/app/api/returns/route.ts** — Return number generato con COUNT non transazionale. Con richieste concorrenti: due resi ottengono stesso numero. Fix: SEQUENCE PostgreSQL via RPC.

3. **src/app/api/contatti/route.ts** — Nessuna validazione schema Zod, nessun limite per-email (spam illimitato da stesso indirizzo).

4. **src/app/api/products/route.ts** — `SELECT *` espone tutti i campi della tabella `products`. Se in futuro si aggiunge `cost_price` o `supplier_id`, saranno esposti al client. Fix: specificare colonne esplicitamente.

Problemi Database

1. **database/rls-policies.sql** — Policy su `orders` usa `auth.jwt()` -> `'role'` invece di JOIN su `profiles.role`. Più fragile se JWT viene modificato.

2. **newsletter_subscribers** — INSERT policy WITH CHECK (TRUE) permette a chiunque di iscriverne email altrui.

3. Indici mancanti probabili: `orders(customer_id)`, `order_items(product_id)`, `reviews(product_id, customer_id)`. Query lente su tabelle grandi.

SEZIONE 3 — AREA ADMIN & DASHBOARD

Cosa funziona bene

- Autenticazione admin robusta con RBAC (`admin`, `super_admin`, `editor`, `order_manager`)
- Dashboard KPI: fatturato oggi/7gg, ordini pending, stock basso
- CRUD prodotti completo: nome, slug, SKU, prezzo, SEO, immagini, varianti
- Lista ordini con filtri stato, ricerca email/numero, cambio status, tracking
- Coupon CRUD: percentuale/importo fisso, date validita, limiti uso globali e per cliente
- Inventario con movimenti e rettifiche manuali
- Moderazione recensioni (approva/rifiuta inline)
- Etsy OAuth2 + sync prodotti/ordini/inventory
- Error log e Audit log (struttura tabelle DB presente)
- Export Packlink CSV + import tracking CSV

Problemi CRITICI

1. Nessun CSRF token su NESSUN endpoint POST/PATCH/DELETE dell'area admin

2. Nessun rate limiting sulle API admin (possibile brute force o flood)

3. **src/app/admin/resi/page.tsx** — Stato `'refunded'` e solo una label nel DB, NON chiama Stripe Refund API. Il rimborso deve essere fatto manualmente dalla Stripe dashboard.

4. **src/app/admin/magazzino/page.tsx** — Race condition: due admin possono fare rettifica inventario contemporaneamente senza locking ottimistico.

Problemi ALTI

1. **src/app/admin/ordini/[id]/page.tsx** — Email di spedizione può essere mandata 2 volte se lo stato torna shipped dopo essere stato processing. Nessun idempotency check su invio email.

2. **src/app/admin/etsy/page.tsx** — Sync completamente manuale (pulsante). Nessun webhook Etsy->SILKINCOM. Con vendite simultanee su Etsy e sito, inventario va out of sync.

3. **src/app/admin/impostazioni/page.tsx** — COMPLETAMENTE READ-ONLY: soglia free shipping (200 EUR), costo spedizione (9 EUR), IVA (22%) sono hardcoded nel codice sorgente, non modificabili da admin.

4. Audit log: la tabella DB esiste ma NESSUNA operazione CRUD admin vi scrive. L'audit è muto.

5. `src/app/api/admin/products/route.ts` — Campo `description_long` non sanitizzato: XSS potenziale nella dashboard admin stessa.

Problemi MEDI

1. Nessun bulk action: impossibile cambiare stato a N ordini contemporaneamente
2. `src/app/admin/clienti/page.tsx` — Totalmente read-only. Nessuna nota privata sul cliente, nessuna segmentazione VIP/at-risk
3. Nessun reply admin alle recensioni pubbliche (risposta visibile ai clienti)
4. Workflow spedizioni completamente manuale: export CSV -> Packlink -> import tracking. Nessuna API automation
5. Nessuna paginazione vera su lista prodotti (limit 200 hardcoded, lento con catalogo grande)
6. Workflow stati ordine permette transizioni illegali: es. delivered -> pending senza controllo

Problemi GDPR (obbligatori per legge)

1. Nessun export dati cliente (art. 20 GDPR — portabilità dei dati)
2. Nessun delete account (art. 17 GDPR — diritto all'oblio)
3. Nessun preference center: il cliente non può gestire consensi newsletter, SMS, email marketing

UX Admin

- Sidebar non responsive su mobile (hidden su schermi piccoli)
- Nessun notification center (bell icon) per alert: stock basso, errori sync Etsy, resi nuovi
- Nessun breadcrumb nelle pagine admin (disorientante dopo molti livelli)

SEZIONE 4 — SHOP & COLLEZIONI

Cosa funziona bene

- Pagine collezioni con SSG e hero elegante
- Pagina prodotto con schema.org Product + BreadcrumbList + ReviewSchema
- Gallery immagini con lazy loading e hover swap
- Related products suggeriti a fine pagina
- Breadcrumb navigation funzionante
- ArtisanAttribution (Made in Italy story, nome artigiano)
- Material labels e composizione tessile

Problemi

1. Nessun filtro prodotti: colore, materiale, prezzo, taglia
2. Nessun sorting: prezzo crescente/decrescente, novità, best seller
3. Nessuna ricerca testuale tra prodotti
4. Nessuna pagination: tutto carica sincrono (problema performance a scala)
5. ProductFilters component presente ma implementazione da verificare
6. Atelier AI Upload (/atelier/ai-upload) — implementazione e status incerto

PRIORITA DI INTERVENTO

PRIORITA 1 — Sicurezza immediata (~8h totali)

#			
1	Race condition cancellazione ordine: UPDATE atomico con .eq('status','pending')	api/orders/[id]/cancel/route.ts	1h
2	Webhook Stripe: risposta 400 quando order_id manca nei metadata	api/stripe/webhook/route.ts	30min
3	HTML escape in tutti i template email (orderNumber, nomi, importi)	lib/email.ts	2h
4	Open redirect auth callback: whitelist domini permessi per 'next'	app/auth/callback/route.ts	30min
5	Schema Zod su payment intent: shipping_address, customer_name, items[]	api/stripe/create-payment-intent/route.ts	3h
6	Sanitize XSS su title e comment delle recensioni	api/reviews/route.ts	1h

PRIORITA 2 — Funzionalità critiche mancanti (~30h totali)

#			
7	Stripe Refund API su approvazione reso	api/admin/returns/[id]/route.ts	4h
8	Impostazioni admin salvate in DB (no piu hardcoded nel codice)	admin/impostazioni + DB migration	8h
9	Audit trail: scrivere log ad ogni operazione CRUD admin	Tutti i route admin	4h
10	Webhook Etsy real-time o cron ogni 5min	api/etsy/*	6h
11	GDPR: export dati + delete account	api/account/export + profilo	6h
12	Email spedizione idempotente (no duplicati su shipped->processing->shipped)	admin/ordini/[id]/page.tsx	2h

PRIORITA 3 — UX e conversioni (~80h totali)

#		
13	Barra di ricerca prodotti	Supabase full-text search o Algolia
14	Filtri + sorting collezioni	Colore, materiale, prezzo, novita
15	Pagination collezioni	Infinite scroll o pagine numerate

1 6	Guest checkout	Senza obbligo di registrazione
1 7	Apple Pay / Google Pay	Gia supportati da Stripe Elements — bastano 2 righe
1 8	Inventory countdown	'Rimasti solo 3!' nella pagina prodotto
1 9	Size guide / tabella misure	Modale o tab nella pagina prodotto
2 0	Rate limiting distribuito	Redis/Upstash invece di in-memory
2 1	Bulk actions admin	Multi-select su ordini e prodotti
2 2	Reply admin a recensioni	Risposta pubblica visibile nel frontend
2 3	Notification center admin	Bell icon: stock basso, resi nuovi, sync error
2 4	Mobile admin responsive	Sidebar come bottom navigation su mobile
2 5	Email notifica cliente su reso	Notifica approvazione o rifiuto del reso

RIEPILOGO EFFORT TOTALE

Fase	Attività	Ore stimate
Priorita 1 — Sicurezza	6 fix critici	~8h
Priorita 2 — Funzionalità	6 feature/fix	~30h
Priorita 3 — UX	13 miglioramenti	~80h
TOTALE		~118h

COSA NON HA BISOGNO DI FIX URGENTI

- Design e UX frontend pubblico — eccellente, nessun intervento necessario
- Autenticazione RBAC admin — funziona correttamente
- Stripe payment flow di base — funziona, webhook gestisce eventi principali
- Supabase RLS — struttura corretta con fix minori già elencati sopra
- SEO metadata e schema.org — ottimi, nessuna modifica urgente
- Newsletter double opt-in — implementazione corretta e sicura
- Gestione coupon — funziona completamente
- Layout internazionalizzazione (next-intl) — funziona su tutte le lingue

